SECCIÓN 8.7

Errores comunes y hábitos de mejora

Temas de esta sección:

- Los errores profesionales más frecuentes del analista SOC
- Checklist profesional diario
- Construir hábitos de mejora continua
- Caso integrador final del módulo

8.7 | Errores profesionales más frecuentes

Estos errores no suelen ser de técnica — son de criterio, comunicación y hábitos:

Confirmar sin evidencia directa

Cerrar casos como falsos positivos sin revisar todas las fuentes relevantes, o confirmar incidente por urgencia.

Documentar insuficientemente

Escribir "revisado OK" sin detallar qué se revisó, qué se descartó y por qué.

Comunicar con alarmismo o ambigüedad

Usar lenguaje vago o alarmante que genera acciones incorrectas o falsa confianza.

No escalar o escalar tarde

Evitar escalar por no "molestar" o esperar demasiado cuando la evidencia ya lo requería.

Actuar fuera del scope o del playbook

Tomar decisiones de contención sin autorización o investigar más allá de lo que el caso permite.

No aprender de los errores

No hacer retrospectiva propia de los casos, no pedir feedback, no actualizar los propios criterios.

Antes de cerrar un caso o terminar el turno, pasá por este checklist:

Análisis y documentación

- ¿Revisé todas las fuentes relevantes para el caso?
- ¿Separé hechos de hipótesis en mi análisis?
- ¿Documenté lo que revisé y lo que descarté?
- ¿El estado del caso es claro para quien lo recibe?
- ¿Los IOCs tienen contexto suficiente?
- ¿Hay timestamps en todas las acciones registradas?
- ¿La documentación permite continuar el análisis sin preguntar?

Comunicación y colaboración

- ¿Comuniqué con nivel de certeza adecuado?
- ¿Usé el canal correcto para cada tipo de dato?
- ¿Escalé cuando correspondía y con el contexto necesario?
- ¿No compartí información más allá de los que necesitaban saberla?
- ¿Hice el handoff correctamente si pasé el caso?
- ¿Actué dentro del playbook y del scope del caso?
- ¿Hay algo que podría haber hecho mejor hoy?

8.7 | Caso integrador final del módulo

Aplicá todo lo del módulo: análisis, comunicación, documentación, ética y colaboración:

```
Escenario completo:
Son las 03:15. El SIEM genera una alerta de alta severidad en DEV-SRV-012 (servidor de desarrollo, equipo de backend).
Cadena: vscode.exe → powershell.exe -nop -enc [base64] → conexión saliente activa a 45.142.212.100:443.
Hay un archivo creado en C:\Users\Shared\temp_update.exe. No hay ticket. Score: 91/100.
El usuario (mlopez) tiene acceso a repositorios privados de la empresa.
Son las 3am — no hay manager de turno disponible, pero hay un L2 en guardia remota.
Los servidores de desarrollo tienen acceso a producción mediante pipeline automatizado.
```

Preguntas integradoras

- ¿Qué es hecho y qué es hipótesis en este caso?
- ¿Qué tan urgente es la contención? ¿Aislás ya?
- ¿A quién notificás y qué les decís exactamente?
- ¿Qué documentás y cómo?
- ¿Qué información NO compartís y por qué?
- ¿Cuándo involucra a IR, Legal o Management?

Respuesta esperada

- Hecho: vscode→PS→conexión saliente + temp_update.exe en Shared. Hipótesis: initial access o implant activo
- Alta urgencia: pipeline a producción. Escalar a L2 remoto antes de aislar
- A L2: evidencia + certeza + riesgo del pipeline + propuesta de acción
- Documentar: timeline, IOCs, proceso origen, ruta del archivo, estado del pipeline
- No compartir: identidad del usuario fuera del canal del caso
- IR si se confirma compromiso; Legal si hay datos de clientes en producción